Pegasus Spyware Scandal

Delilah Hollander

November 9, 2025

Abstract

The Pegasus spyware scandal marked a global ethical turning point in how societies understand digital privacy, surveillance, and state power. Developed by NSO Group, Pegasus exploited a chain of iPhone vulnerabilities to secretly access private communications and data from journalists, activists, and world leaders. Its exposure revealed not only technical weaknesses in personal devices but also moral gaps in how governments and companies regulate cyber tools. The scandal forced a worldwide reckoning over digital rights, leading to lawsuits, export restrictions, and growing calls for transparency in the surveillance industry. By blurring the line between security and violation, Pegasus shifted global norms around cybersecurity ethics, making privacy protection a central human rights concern in the digital age.

Keywords: Pegasus, NSO Group, spyware, surveillance, digital privacy, cybersecurity, human rights

Pegasus Spyware Scandal

Introduction and Technical Overview

The Pegasus spyware scandal, uncovered between 2016 and 2021, exposed how advanced surveillance technologies developed by private companies can be turned into tools of repression and global privacy violations. Created by the Israeli company NSO Group, Pegasus used a chain of three software vulnerabilities—known collectively as the Trident exploit—to silently infect iPhones through a single malicious link. Once installed, the spyware gained access to nearly every function of a victim's device, including messages, calls, microphones, cameras, and location data, while concealing its presence through self-destruct and anti-forensic mechanisms.

This paper argues that Pegasus exemplifies the dangers of unregulated surveillance markets, where concentrated technological power and commercial incentives outpace legal and ethical oversight. Drawing on primary research from Citizen Lab, Lookout, and technical presentations such as Black Hat Europe 2016, this study breaks down how the Trident exploit operated, how Pegasus weaponized ordinary smartphone functions into tools of intelligence gathering, and how governments, journalists, and human rights organizations responded. The findings reveal that Pegasus not only exploited software vulnerabilities but also exposed institutional weaknesses in global cybersecurity governance. Apple's rapid release of iOS 9.3.5 patched the initial Trident vulnerabilities, yet the scandal prompted larger questions about accountability, transparency, and digital sovereignty.

Ultimately, Pegasus stands as a cautionary tale. It demonstrates how unregulated flows of digital information can undermine democracy when concentrated in the hands of a few. NSO's "business first, diplomacy later" mindset prioritized profit over ethics, removing moral

accountability from its operations. The scandal also reveals how knowledge itself—who collects it, interprets it, and acts upon it—is a form of power shaped by political and economic forces.

Anatomy of Information

The Pegasus scandal illustrated a data and information lifecycle, from creation to circulation. The process begins with everyday digital activities: phone usage, with each app and function tracking different categories of personal information. Each piece of that information contributes to a predictive profile of a person's movements and interactions. Under ordinary circumstances, this information is encrypted and protected by security safeguards; Pegasus circumvents all of these protections. This specific capability of the spyware can be classified as "tapping"—the recording and storage of communications by a third party without the knowledge or consent of the owner.

Once collected and processed through NSO's servers, the data is analyzed through proprietary algorithms and then disseminated to client governments. From a basic information-theoretic perspective, each piece of information captured by the spyware reduces privacy while increasing the completeness of an intelligence package available to bad actors. Importantly, each piece of this data must be reviewed by human analysts who determine what is relevant—meaning that each analyst, in some way, bears personal responsibility for how that data is ultimately used. Haraway's (1988) concept of situated knowledge offers insight into this process: processed information is not neutral truth but is interpreted through the priorities and biases of its collectors. When a government contracts NSO's Pegasus to fight terrorism, the knowledge assembled will reflect actionable categories shaped by a specific political perspective. As Haraway (1988) argued, "the object of knowledge [should be] pictured as an actor and agent" (p.

592). Information provided by NSO therefore reflects only a partial perspective and cannot be treated as a universal reality.

Dissemination of that information occurred in various ways. In Mexico, for instance, leaked intelligence reports in 2017 revealed that journalists investigating corruption were targeted using Pegasus, reshaping the national debate on surveillance and privacy (Citizen Lab, 2022). The information pipeline—from personal data to state intelligence—carries enormous hidden costs in labor, resources, and infrastructure.

Historical Context: Counterterrorism and Surveillance

To understand how Pegasus emerged from decades of shifting global priorities, it is important to trace the evolution of counterterrorism and surveillance policies leading up to its creation. Pegasus did not emerge in a vacuum; it is the product of decades of steadily expanding surveillance and counterterrorism policies. The forces of globalization and widespread media coverage intensified both public and governmental responses to terrorism. This evolving era can be divided into several distinct periods, each shaped by the major global events unfolding at the time.

Pre-9/11 Era (1972–2001)

This era saw a series of more isolated attacks, with 23 documented events illustrating the progression toward global recognition of a patterned problem. Attacks were viewed primarily as national security incidents rather than unified global threats. Intelligence responses were reactive and often constrained by borders. Governments, whether individually or in collaboration, had not yet adopted a shared framework for counterterrorism.

Post-9/11 Shock (2001–2002)

The September 11, 2001 attacks—three coordinated strikes facilitated through the hijacking of commercial aircraft—fundamentally transformed the global paradigm for understanding terrorism. This event accelerated the dismantling of existing intelligence frameworks and created the political will for sweeping surveillance expansion.

War on Terrorism (2001–2010)

In 2002 alone, there were four major global terror attacks, further heightening international fear and accelerating investment in counterterrorism technologies. Nations began to invest in technologies and personnel capable of tracking and neutralizing potential threats. Counterterrorism became both a military strategy and a political priority in this era. The creation and usage of counterterrorism tools laid the ethical foundation—however contested—for technologies like Pegasus.

Justification Through Expansion (2010s)

The landscape of terrorism was shifting. No longer commonly confined to physical acts, online threats were becoming commonplace. Widespread usage of surveillance had become a preventative method, and this led to the creation and improvements of systems like Pegasus globally.

Turning Point (2016–2021)

The global exposure of Pegasus between 2016 and 2021 revealed just how far "ethical" justifications can go unchecked and unchallenged. What might have begun as a counterterrorism tool had evolved into a mechanism of political control. Pegasus marked a shift in public perception; citizens could no longer trust that their governments would use such powerful tools solely for the greater good.

It is also important to recognize that while these eras present a timeline of how counterterrorism grew to be a central governmental concern, these events alone do not fully explain or justify an ethical shift toward the normalization of surveillance. It remains a moral question: what changes in the nature or scale of terrorism, if any, could justify the deployment of spyware such as Pegasus against civilians under the broad supposition of a terrorism threat?

Cybersecurity Analysis

To understand the technical process in greater depth, it is necessary to first understand the workflow of the code. Pegasus spyware infects phones through a method called a Trident infection. First reported by Citizen Lab in 2016, it is a tri-pronged exploit chain consisting of an initial browser exploit, a kernel information disclosure step, and a kernel privilege escalation that installs the spyware payload (Black Hat Europe, 2016; Citizen Lab, 2022).

As Lookout's (2016) technical report explains, the attack begins when an attacker sends a malicious website URL to the target—the victim need only click the link. This was documented in the Mansoor case, the first publicly confirmed instance of Pegasus being used unjustly against a private citizen. After the browser infection, the exploit chain uses a kernel information leak to remove address space layout randomization, and the kernel exploit then gains full privileges and installs the spyware. Analysis across multiple research labs, cross-referenced by victim testimony, confirmed Pegasus's involvement and demonstrated it was being deployed against civilians (Citizen Lab, 2022; Lookout, 2016). Once installed, the spyware behaves like a persistent background service, collecting data from a wide range of apps and communications while remaining hidden. Lookout (2016) noted that Pegasus "constantly monitors the phone for status" and disables competing jailbreaking software. The kernel privilege escalation also prevents the device from receiving operating system updates—the very updates that keep

security protections current and protect users from exploitative software. Both Citizen Lab and Lookout noted that Pegasus's own name appeared in the code and permissions, and that the network servers used by the spyware were publicly registered to NSO Group.

In 2019, a WhatsApp missed-call vulnerability reported by Facebook allowed Pegasus to infect phones through a missed voice call, representing one of the earliest indications of how sophisticated spyware could exploit messaging platforms without any user interaction. In 2020, an iMessage zero-click exploit called "KISMET" was reported and patched by Apple, affecting phones running iOS 13 (Marczak et al., 2020). That same year, a vulnerability in Samsung Knox allowed Pegasus to infect Android devices via unauthorized system control, demonstrating that both major mobile operating systems were susceptible to state-level spyware attacks (Android Security Bulletin, 2020).

By 2021, Citizen Lab had publicized an exploit enabling full compromise of an iPhone through a malicious PDF requiring no user interaction, and forensic researchers identified at least six Pegasus zero-click exploits within iOS 1–14, targeting messaging apps and kernel-level flaws. Kernel-level flaws are weaknesses deep within a device's operating system, where memory, files, apps, and communications interact with hardware (Bishop, 2003). These flaws bypass standard security protections, allowing attackers full control of the device without the user's knowledge. Later that year, Apple released iOS 15 with the BlastDoor sandbox designed to block malicious messages (Apple, 2021). Apple also filed a lawsuit against NSO Group in U.S. federal court. The Biden Administration subsequently added NSO Group to the Entity List, which restricts U.S. firms from exporting certain goods, software, or technology to entities deemed a threat to national security or human rights (U.S. Department of Commerce, 2021).

Power Mapping

Pegasus brought together a complex network of power, interests, and relationships. With NSO at the center and connecting to client governments, the information that passed between them changed the lives of citizens and journalists permanently. Countries including India, Mexico, Hungary, Saudi Arabia, Bahrain, and the United Arab Emirates reportedly contracted NSO to monitor political opponents, journalists, and activists, altering the political landscape and accelerating the erosion of public trust (Citizen Lab, 2022).

Victims who were surveilled shared their experiences and evidence with journalists and human rights organizations, which allowed those groups to investigate and expose the Pegasus scandal publicly, shifting opinion and raising awareness about digital surveillance abuse. In response, journalists and advocacy groups pressured governments to cease misusing Pegasus and to take accountability for human rights violations. This public exposure weakened government power and initiated global conversations about privacy and regulation. Meanwhile, tech companies including Apple and WhatsApp took legal action against NSO Group and addressed the security vulnerabilities that Pegasus had exploited. This limited NSO's operational reach and reduced governments' ability to conduct surveillance through the spyware. By improving security protections, these companies also helped protect ordinary users, journalists, and activists from future attacks—returning some measure of power to individuals and strengthening digital safety broadly.

Global Responses and Policy Developments

Since 2022, cybersecurity and cyberterrorism policies have continued to evolve amid growing global concern over state surveillance. Governments have debated the limits of encryption, lawful access, and oversight of spyware tools, while private contractors operating on behalf of state authorities have faced heightened scrutiny. In the United States, in May 2025,

NSO Group was ordered to pay nearly $170 million in damages to WhatsApp for exploiting approximately 1,400 user accounts (Politico, 2025). In Europe, the European Parliament urged member states in June 2023 to impose stricter regulations on spyware such as Pegasus, emphasizing judicial oversight and transparency in surveillance practices (EUCRIM, 2023). The Parliament's PEGA Committee released a report in March 2023 documenting extensive misuse of spyware and recommending reforms to prevent future abuses (European Parliament, 2023).

One of the most significant regulatory frameworks to emerge from international deliberations is the Wassenaar Arrangement, an agreement among 42 participating governments designed to control the export of military and dual-use technologies. Although the arrangement targets specific classes of technologies rather than individual companies, it has advanced collective efforts to limit the expansion of invasive spyware and to apply export controls that prevent human rights abuses linked to hacking tools (The Wassenaar Arrangement, n.d.).

Advocacy organizations such as Amnesty International continue to call for comprehensive global measures to prevent spyware misuse, most recently publishing a major report on the topic in September 2025 (Amnesty International, 2025). Similarly, Citizen Lab's 2025 reports on censorship and surveillance highlight persistent risks and reinforce the urgent need for transparent regulatory accountability (Citizen Lab, 2025). Taken together, these developments underscore the growing importance of coordinated international oversight to prevent the abuse of surveillance technologies in a rapidly evolving digital landscape.

Statistical Discrepancies and Accountability

In 2017, NSO Group reported that Pegasus had been purchased for use by three categories of clients: 51% intelligence agencies, 38% law enforcement agencies, and 11% military entities (NSO Group Technologies, 2017). However, this claim appears inconsistent

with later evidence. Citizen Lab's (2022) reports on confirmed Pegasus victims reveal a vastly different reality. Although NSO asserted that Pegasus was sold exclusively to government bodies for legitimate security purposes, verified victim data show that over half of those targeted (approximately 53%) were journalists, along with approximately 10.7% activists, 8.5% government officials, and 7% lawyers.

These statistics reveal that Pegasus was not merely a tool of national security but a mechanism disproportionately impacting journalists, lawyers, and activists. The mismatch between NSO Group's stated intentions and the actual deployment of the spyware underscores the systemic risks of unregulated spyware sales. By targeting individuals critical to transparency and accountability, Pegasus threatened the foundational principles of civil society, demonstrating how concentrated technological power can circumvent legal and ethical safeguards. This pattern reinforces the urgency for international oversight, transparent accountability mechanisms, and human-rights-based frameworks in regulating surveillance technologies.

Conclusion

Pegasus is a cautionary tale, showing how hidden flows of information can destabilize societies when left unchecked. The concentration of power in covert spyware threatens democracy and individual rights alike. Functioning under a philosophy of "business first, diplomacy later," NSO Group prioritized profit and state contracts over moral responsibility or ethical restraint. This mindset allowed the company to act in ways that disregarded human rights and removed moral accountability from its business model.

Each participating organization and journalist approached the Pegasus scandal through different lenses, shaped by institutional values, political pressures, and international tensions. Because NSO Group operates within Israel, much of the analysis surrounding Pegasus reflects

not only concerns over privacy and human rights but also broader skepticism toward the Israeli government. This intertwining of political narratives and investigative reporting blurred the line between empirical evidence and interpretive framing of intent. It serves as a reminder that so-called "objective" intelligence is often produced within contested global discourses.

The broader implications are profound. Pegasus underscores the urgent need for an international framework that treats digital privacy as a human right and surveillance technology as a matter of global governance. As cybersecurity continues to intertwine with geopolitics, the central ethical question remains: can the pursuit of security ever justify tools that fundamentally erode the very freedoms they claim to protect?

References

Amnesty International. (2021). Case study: The Pegasus Project. Amnesty International Security Lab.

Amnesty International. (2023, December 28). India: Damning new forensic investigation reveals repeated use of Pegasus spyware to target high-profile journalists. https://www.amnesty.org

Amnesty International. (2025, September). Pakistan: Mass surveillance and censorship machine is fueled by Chinese, European, Emirati, and North American companies. https://www.amnesty.org

Android Security Bulletin. (2020). July 2020 security bulletin. Android Open Source Project.

Apple Inc. (2021, November 23). Apple sues NSO Group to curb the abuse of state-sponsored spyware. Apple Newsroom. https://www.apple.com/newsroom

Bishop, M. (2003). Computer security: Art and science. Addison-Wesley.

Black Hat Europe. (2016). Exploiting the Trident vulnerabilities: Pegasus case study. Black Hat Europe Conference Proceedings.

Citizen Lab. (2022). Pegasus Project reports and victim dataset. University of Toronto.

Citizen Lab. (2025). Pegasus symposium: Censorship and surveillance 2025 report. University of Toronto.

Council of Europe. (2022, January). Pegasus spyware and its implications on human rights.

Crawford, K., & Joler, V. (2018). Anatomy of an AI system: The Amazon Echo as an anatomical map of human labor, data and planetary resources. AI Now Institute and Share Lab.

Dhillon, A., & Safi, M. (2021, October 27). Indian Supreme Court orders inquiry into state's use of Pegasus spyware. The Guardian. https://www.theguardian.com

EUCRIM. (2023, June). EP recommendation on lessons learned from misused spyware. EUCRIM: The European Criminal Law Associations' Forum.

European Parliament. (2023, March). PEGA: Committee of inquiry to investigate the use of Pegasus and equivalent surveillance spyware. https://www.europarl.europa.eu

FRONTLINE, Forbidden Stories, & Forbidden Films. (2023, January 3 & 10). Global spyware scandal: Exposing Pegasus [Television documentary series]. PBS.

Haraway, D. (1988). Situated knowledges: The science question in feminism and the privilege of partial perspective. Feminist Studies, 14(3), 575–599. https://doi.org/10.2307/3178066

Lookout Security Intelligence. (2016). Trident exploit chain and Pegasus spyware technical analysis. Lookout.

Marczak, B., Scott-Railton, J., Razzak, B. A., Deibert, R., & Crete-Nishihata, M. (2020, December). The great iPwn: Journalists hacked with suspected NSO Group iMessage zero-click exploit. Citizen Lab.

Marczak, B., Scott-Railton, J., Razzak, B. A., Deibert, R., & Crete-Nishihata, M. (2021, September 13). FORCEDENTRY: NSO Group iMessage zero-click exploit captured in the wild. Citizen Lab.

NSO Group Technologies. (2017). Internal Pegasus client use report.

O'Ceabhail, D., & Marczak, B. (2022, September). Exploit archaeology: A forensic history of in-the-wild NSO Group exploits. Virus Bulletin Conference Proceedings.

Politico. (2025, May 6). NSO ordered to pay nearly $170 million in WhatsApp damages. https://www.politico.com

Shoot the messenger: Espionage, murder & Pegasus spyware [Podcast]. (2022–2025). Exile Content Studio and PRX.

The Wassenaar Arrangement. (n.d.). About us. https://www.wassenaar.org

U.S. Department of Commerce, Bureau of Industry and Security. (2021, November 4). Commerce adds NSO Group and other foreign companies to Entity List for malicious cyber activities. https://www.bis.doc.gov